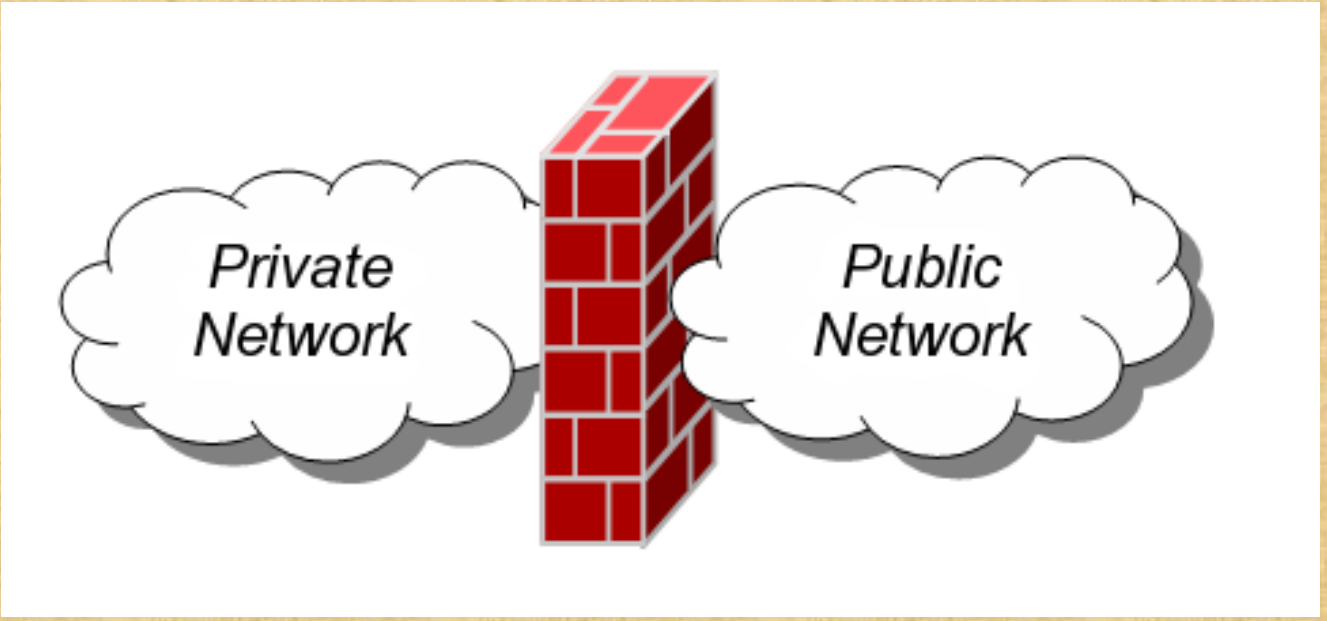
Chapter 6 : Network Security II

Firewall, Tunneling, Intrusion Detection

Firewall

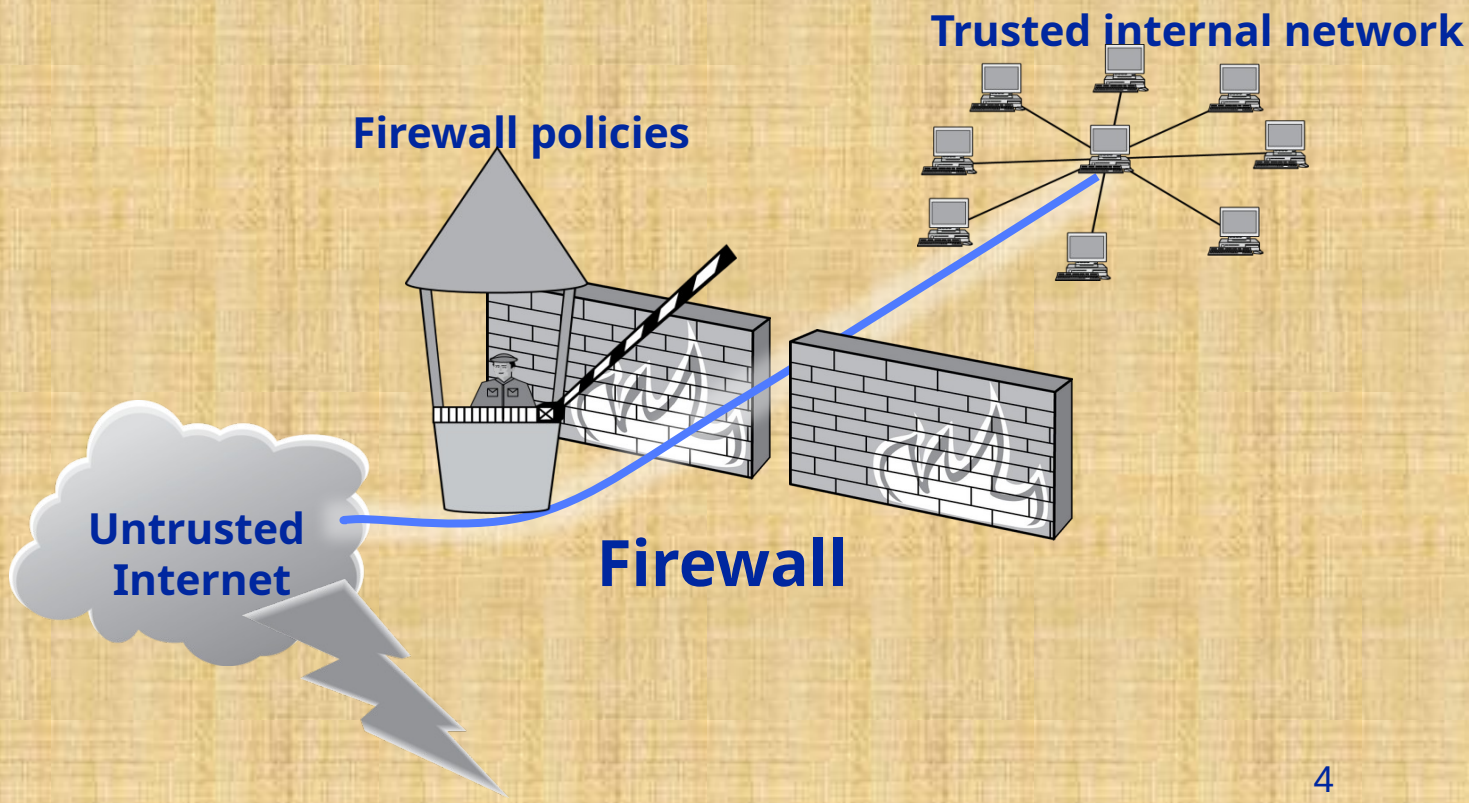
Firewalls

- A **firewall** is an integrated collection of security measures designed to prevent unauthorized electronic access to a networked computer system.
- A network firewall is similar to firewalls in building construction, because in both cases they are intended to isolate one "network" or "compartment" from another.



Firewall Policies

- To protect private networks and individual machines from the dangers of the greater Internet, a firewall can be employed to filter incoming or outgoing traffic based on a predefined set of rules called **firewall policies**.



Policy Actions

- Packets flowing through a firewall can have one of three outcomes:
  - **Accepted:** permitted through the firewall
  - **Dropped:** not allowed through with no indication of failure
  - **Rejected:** not allowed through, accompanied by an attempt to inform the source that the packet was rejected
- Policies used by the firewall to handle packets are based on several properties of the packets being inspected, including the protocol used, such as:
  - TCP or UDP
  - **the source and destination IP addresses**
  - **the source and destination ports**
  - the application-level payload of the packet (e.g., whether it contains a virus).

Blacklists and White Lists

- Two fundamental approaches to creating firewall policies (or rulesets)

- **Blacklist** approach (default-allow)
  - All packets are allowed through except those that fit the rules defined specifically in a blacklist.
  - Pros: flexible in ensuring that service to the internal network is not disrupted by the firewall
  - Cons: unexpected forms of malicious traffic could go through

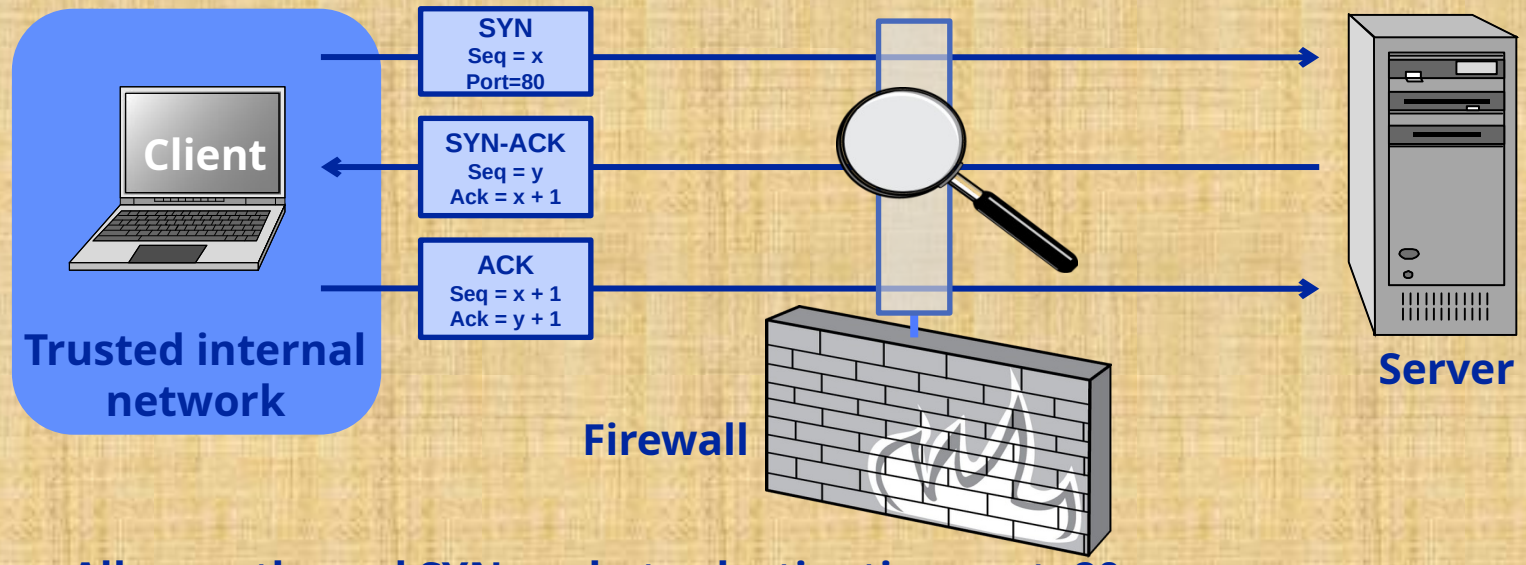
- **Whitelist** approach (default-deny)
  - Packets are dropped or rejected unless they are specifically allowed by the firewall
  - Pros: A safer approach to defining a firewall ruleset
  - Cons: must consider all possible legitimate traffic in rulesets

Firewall Types

- **Packet filters (stateless)**
  - If a packet matches the packet filter's set of rules, the packet filter will drop or accept it
- **“Stateful" filters**
  - it maintains records of all connections passing through it and can determine if a packet is either the start of a new connection, a part of an existing connection, or is an invalid packet.
- **Application layer**
  - It works like a **proxy** it can “understand” certain applications and protocols.
  - It may inspect the contents of the traffic, blocking what it views as inappropriate content (i.e. websites, viruses, vulnerabilities, ...)

Stateless Firewalls

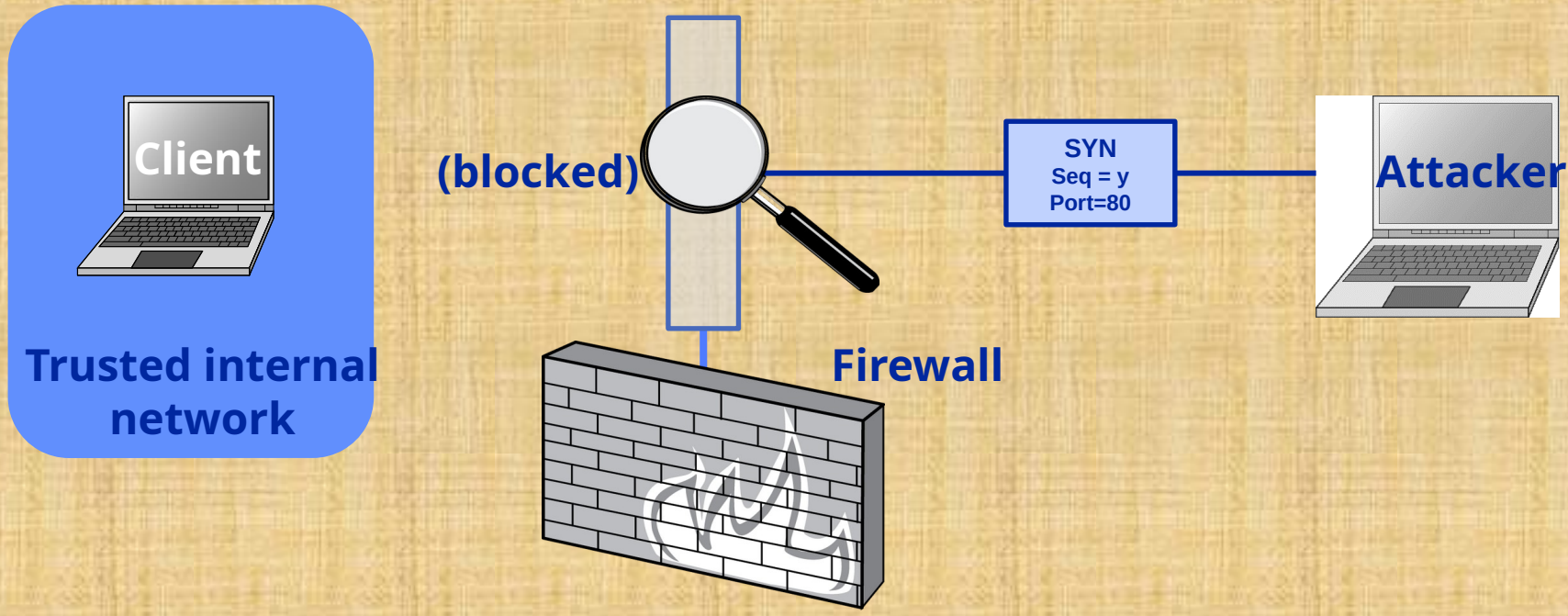
- A stateless firewall doesn't maintain any remembered context (or "state") with respect to the packets it is processing. Instead, it treats each packet attempting to travel through it in isolation without considering packets that it has processed previously.



Allow outbound SYN packets, destination port=80
Allow inbound SYN-ACK packets, source port=80

Stateless Restrictions

- Stateless firewalls may have to be fairly restrictive in order to prevent most attacks.



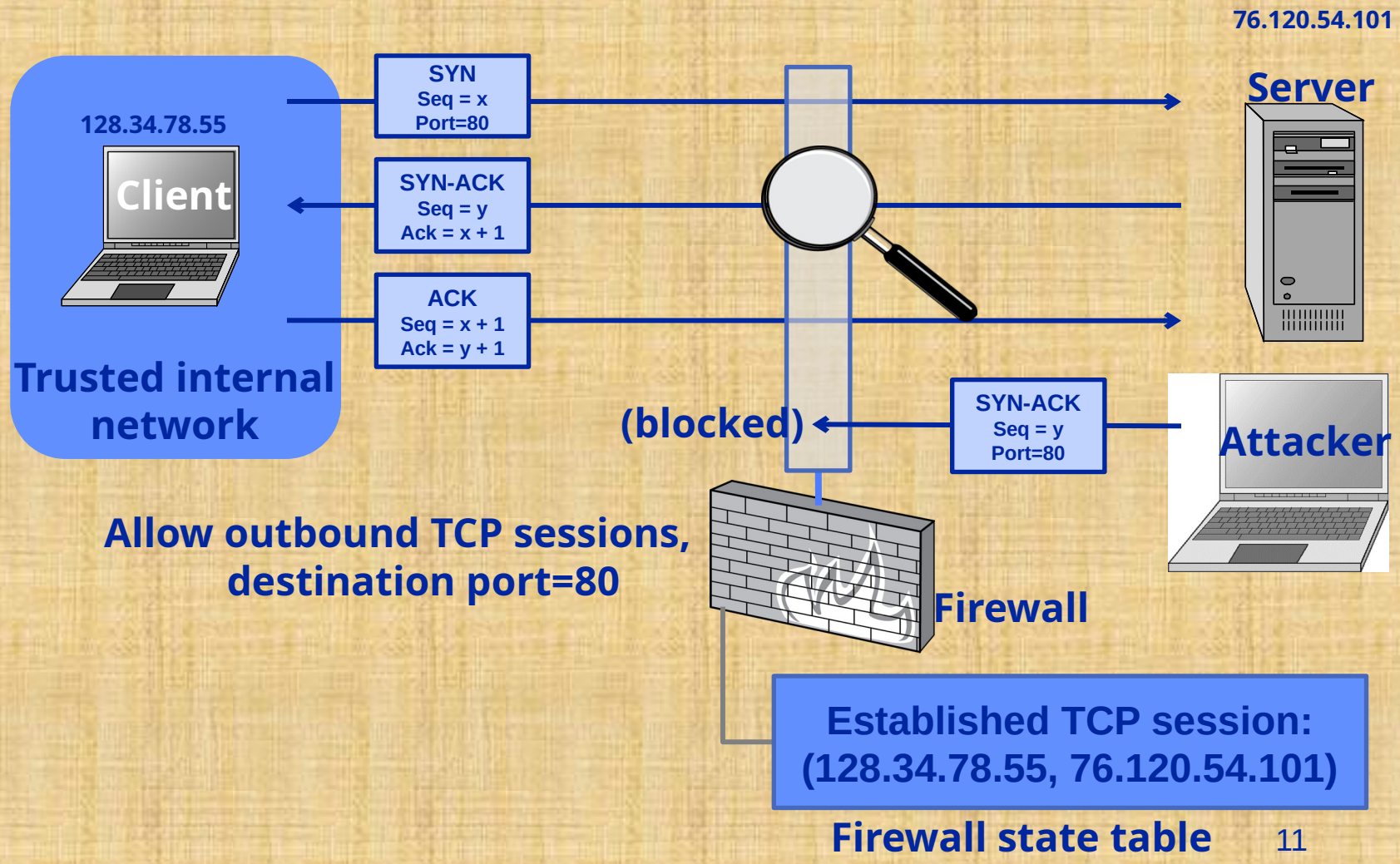
Allow outbound SYN packets, destination port=80
Drop inbound SYN packets,
Allow inbound SYN-ACK packets, source port=80

Stateful Firewalls

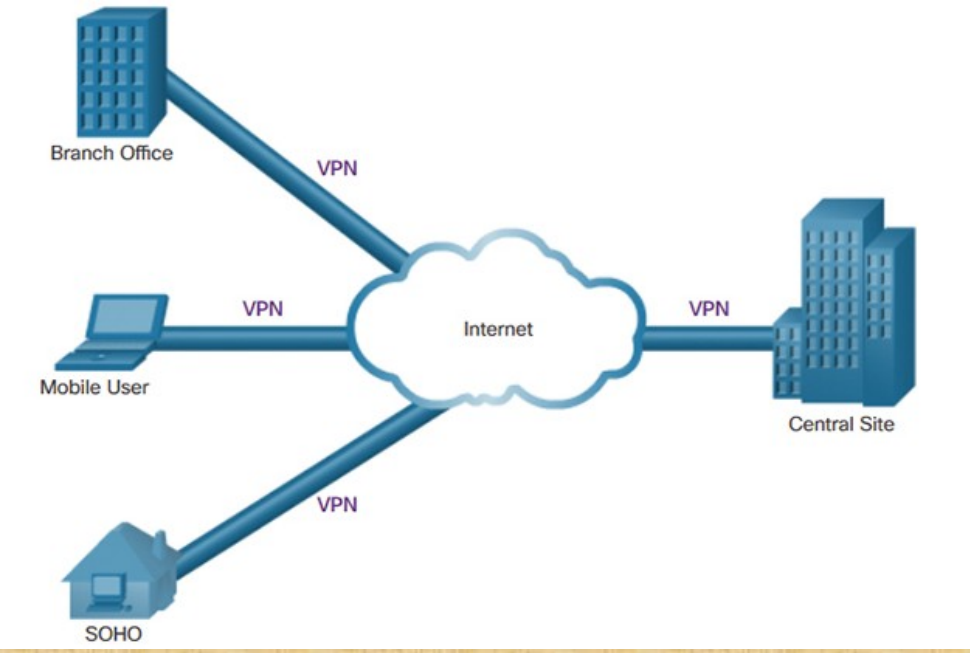
- **Stateful firewalls** can tell when packets are part of legitimate sessions originating within a trusted network.
- Stateful firewalls maintain tables containing information on each active connection, including the IP addresses, ports, and sequence numbers of packets.
- Using these tables, stateful firewalls can allow only inbound TCP packets that are in response to a connection initiated from within the internal network.

Statefull Firewall Example

- Allow only requested TCP connections:



Virtual Private Network (VPN) Tunneling

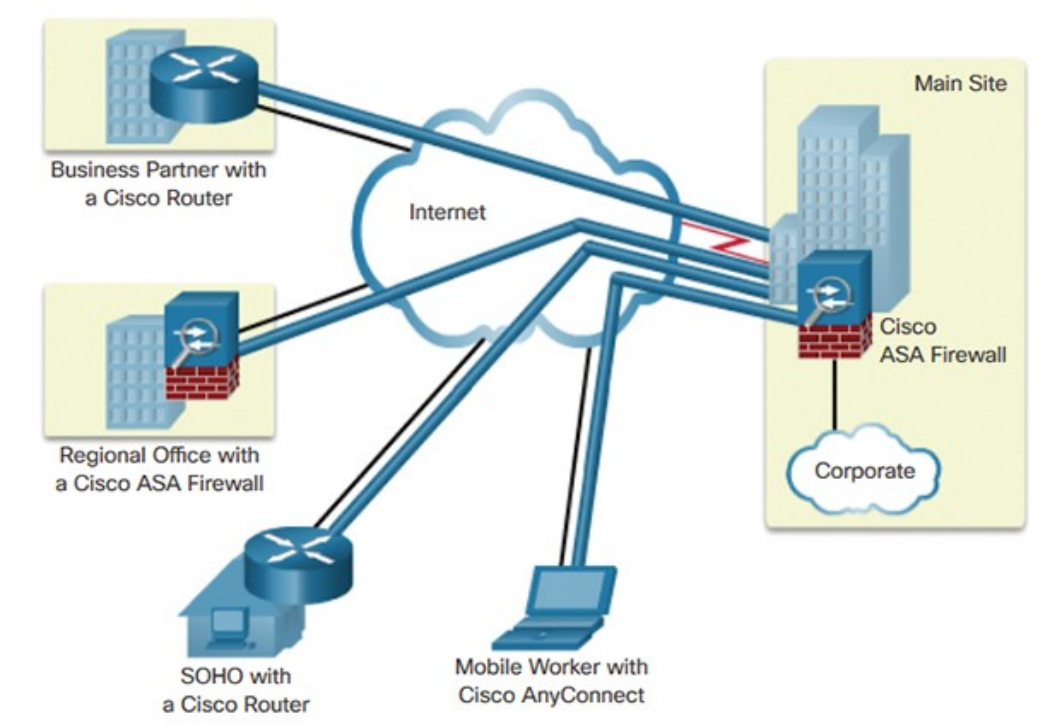


Tunnels

- The contents of TCP packets are not normally encrypted
- If someone is eavesdropping on a TCP connection, he can often see the complete contents of the payloads in this session.
- To prevent such eavesdropping without changing the software performing the communication: **tunneling protocol.**
- In such a protocol, the communication between a client and server is automatically encrypted, so that useful eavesdropping is infeasible.

Benefits of VPN

- Cost saving
- Scalability
- Security
- Compatibility

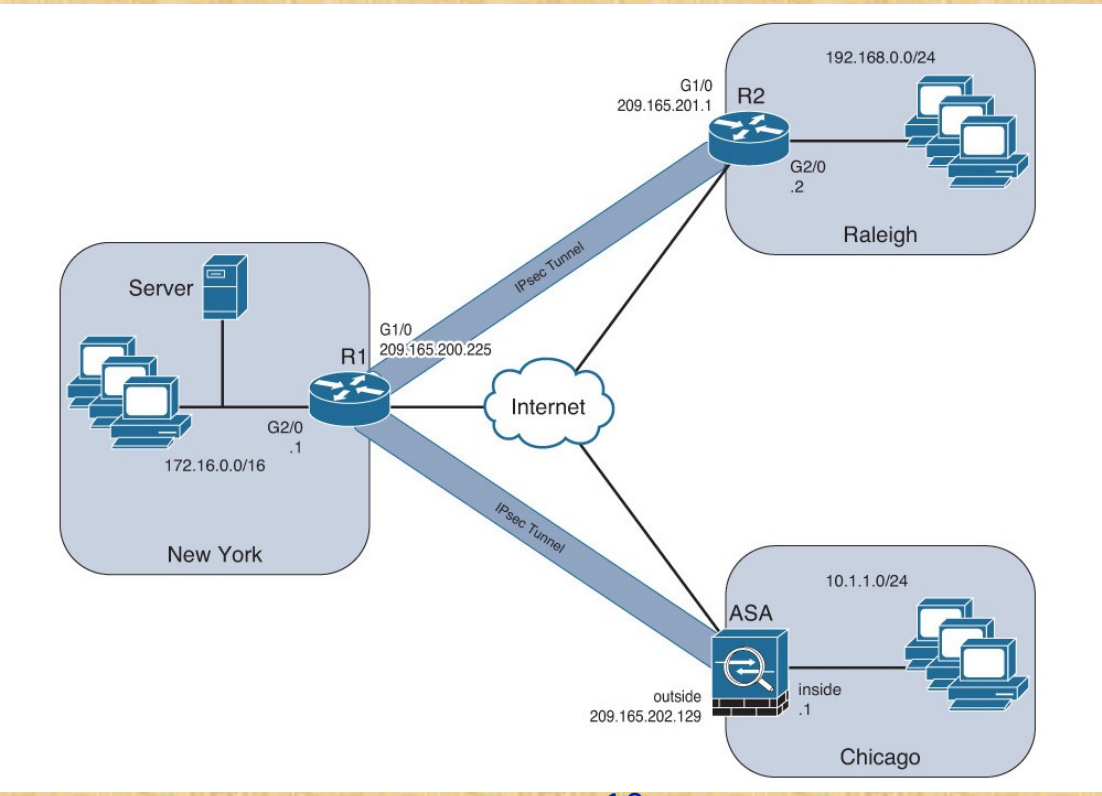


Virtual Private Networking (VPN)

- A technology that allows private networks to be safely extended over long physical distances by making use of a public network, such as the Internet
- VPN provides guarantees of data confidentiality, integrity, and authentication, despite the use of an untrusted network for transmission.
- There are two primary types of VPNs,
  - **Site-to-site VPN**
  - **Remote access VPN**

Site-to-Site VPN

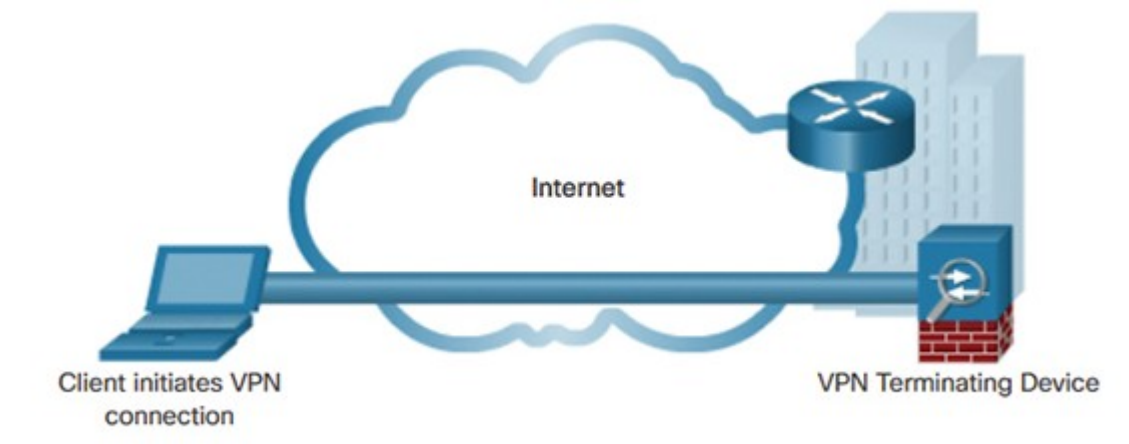
- **Site-to-site** VPN solutions are designed to provide a secure bridge between two or more physically distant networks.
  - Before VPN, organizations wishing to safely bridge their private networks purchased expensive leased lines



https://www.oreilly.com/library/view/santosccna-sec-210-260/9780134077857/ch07lev2sec3.html

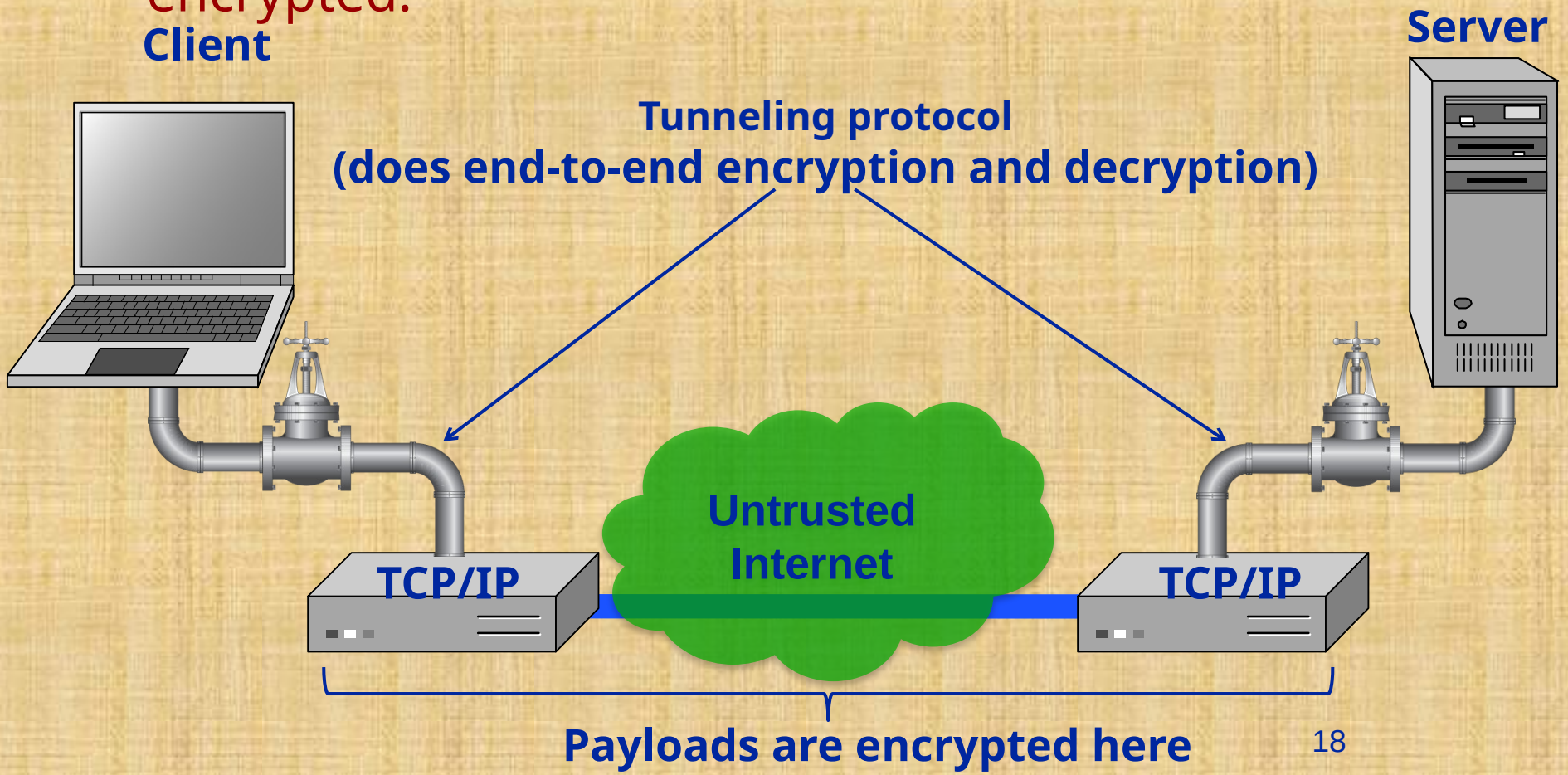
Remote Access VPN

- **Remote access** VPNs allow authorized clients to access a private network that is referred to as an **intranet.**
  - E.g., UCF VPN. Computer has internal IP when connected.
  - Set up a VPN endpoint, **network access server (NAS)**
    - Clients install VPN client software on their machines.



Tunneling Prevents Eavesdropping

- Packets sent over the Internet are automatically encrypted.

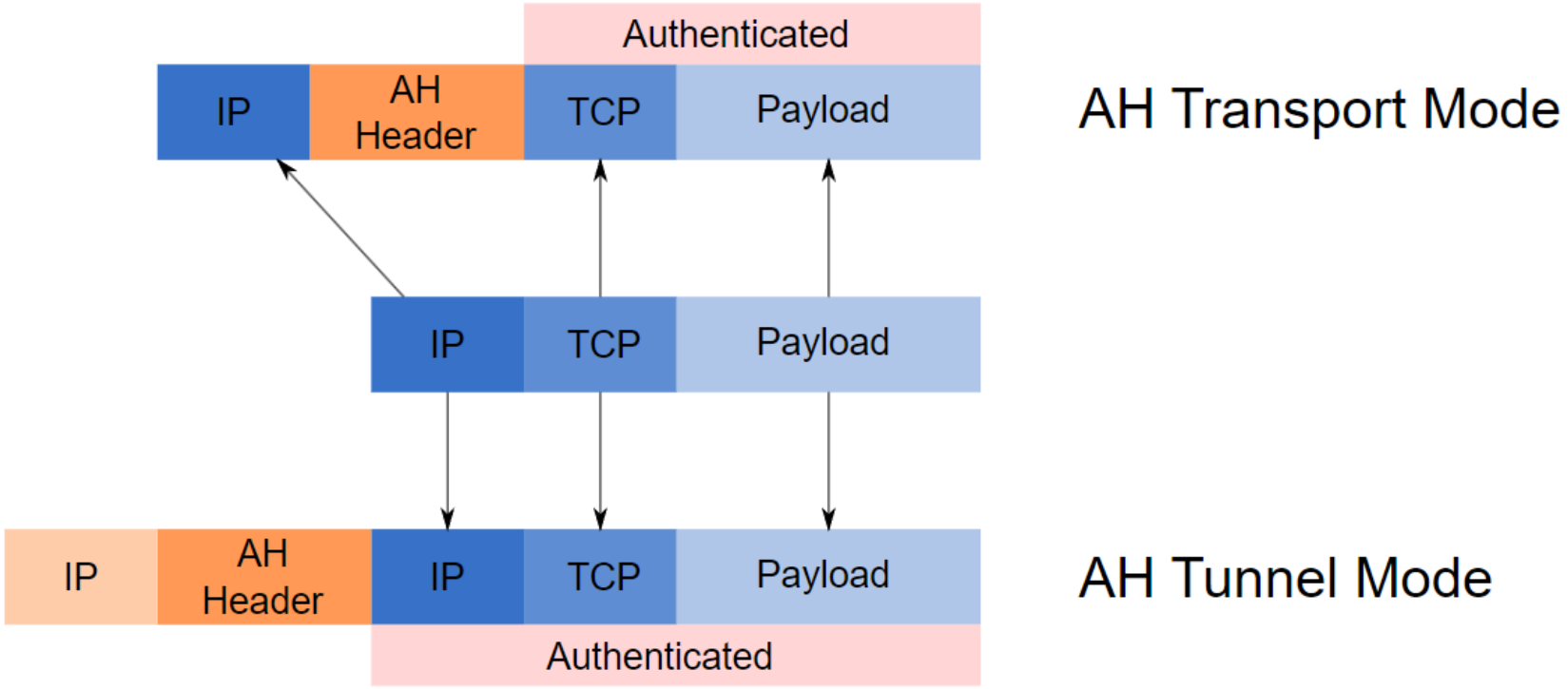


IPSec

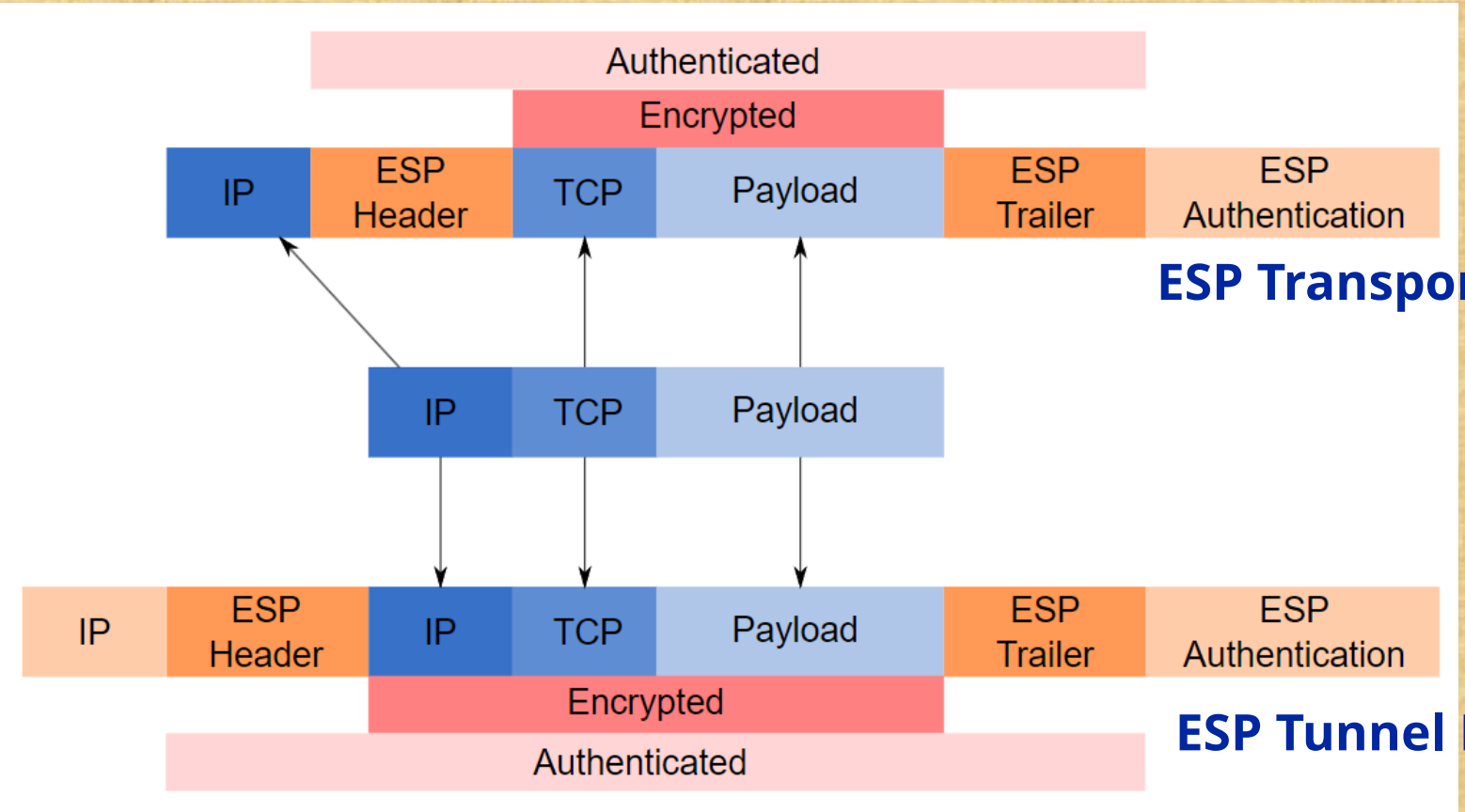
IPSec

- IPSec defines a set of protocols to provide confidentiality and authenticity for IP packets
- Authentication Header (AH)
  - provides connectionless integrity and data origin authentication for IP datagrams
  - provides protection against replay attacks
  - No confidentiality (packets are still unencrypted)
- Encapsulating Security Payload (ESP)
  - provides confidentiality, data-origin authentication, connectionless integrity, and limited traffic-flow confidentiality.
  - Port numbers are encrypted, poses challenge for NAT
- http://en.wikipedia.org/wiki/IPsec

AH header encapsulation



ESP header encapsulation



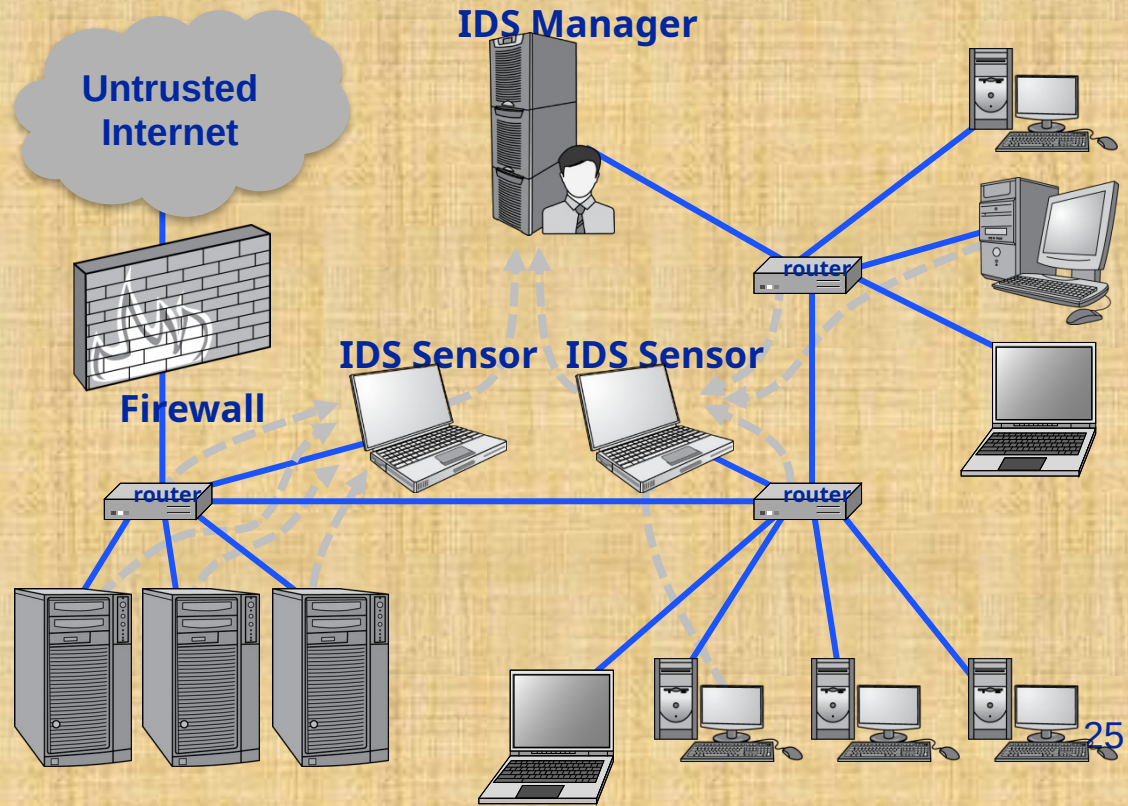
Intrusion Detection System

Intrusion Detection Systems

- **Intrusion**
  - Actions aimed at compromising the security of the target (confidentiality, integrity, availability of computing/networking resources)
- **Intrusion detection**
  - The identification through intrusion signatures and report of intrusion activities
- **Intrusion prevention**
  - The process of both detecting intrusion activities and managing automatic responsive actions throughout the network

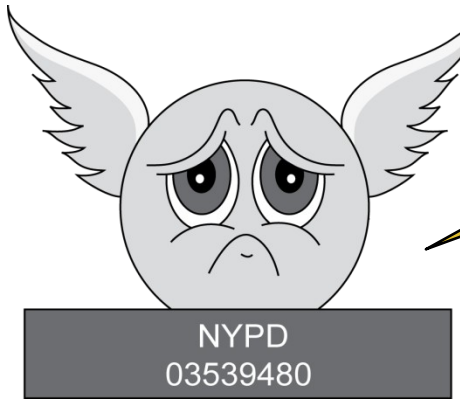
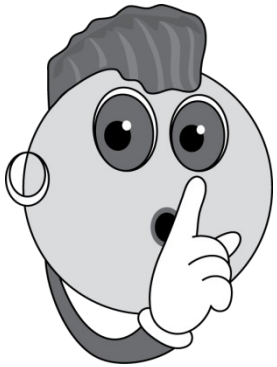
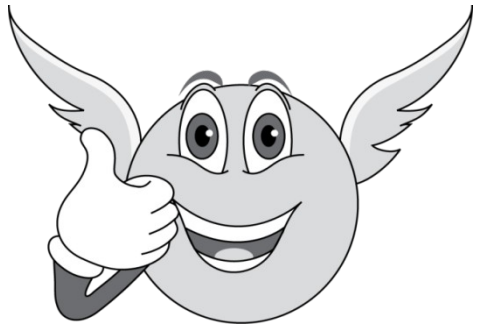
IDS Components

- **IDS manager** compiles data from the IDS sensors to determine if an intrusion has occurred.
- If an IDS manager detects an intrusion, then it sounds an **alarm**.



Possible Alarm Outcomes

- Alarms can be sounded (positive) or not (negative)

	Intrusion Attack	No Intrusion Attack
Alarm Sounded	 True Positive	 False Positive
No Alarm Sounded	 False Negative	 True Negative

Bad (reject normal)

Bad (miss attack)

Port Scanning

Port Scanning

- Purpose: Attackers need to know where a potential target is
- TCP scan: use OS system call to check if TCP connection can be set up on a target machine on any port
  - Example scanner: nmap
  - See how nmap works on department eustis machine!
- SYN scan: low-level TCP program to send out SYN packet without intent to finish the TCP connection setup
  - On receiving SYN/ACK, issues a RST packet to terminate

Port Scanning

- Two port scanning mode:
  - Vertical scan: target numerous destination ports on a singular host (e.g., nmap)
  - Horizontal scan: target the same port on many target hosts, effectively looking for a specific vulnerability: worm
  - Attacker conduct reconnaissance before real attack

TCP SYN scan

```
root:~# nmap -sS -O 192.168.1.101

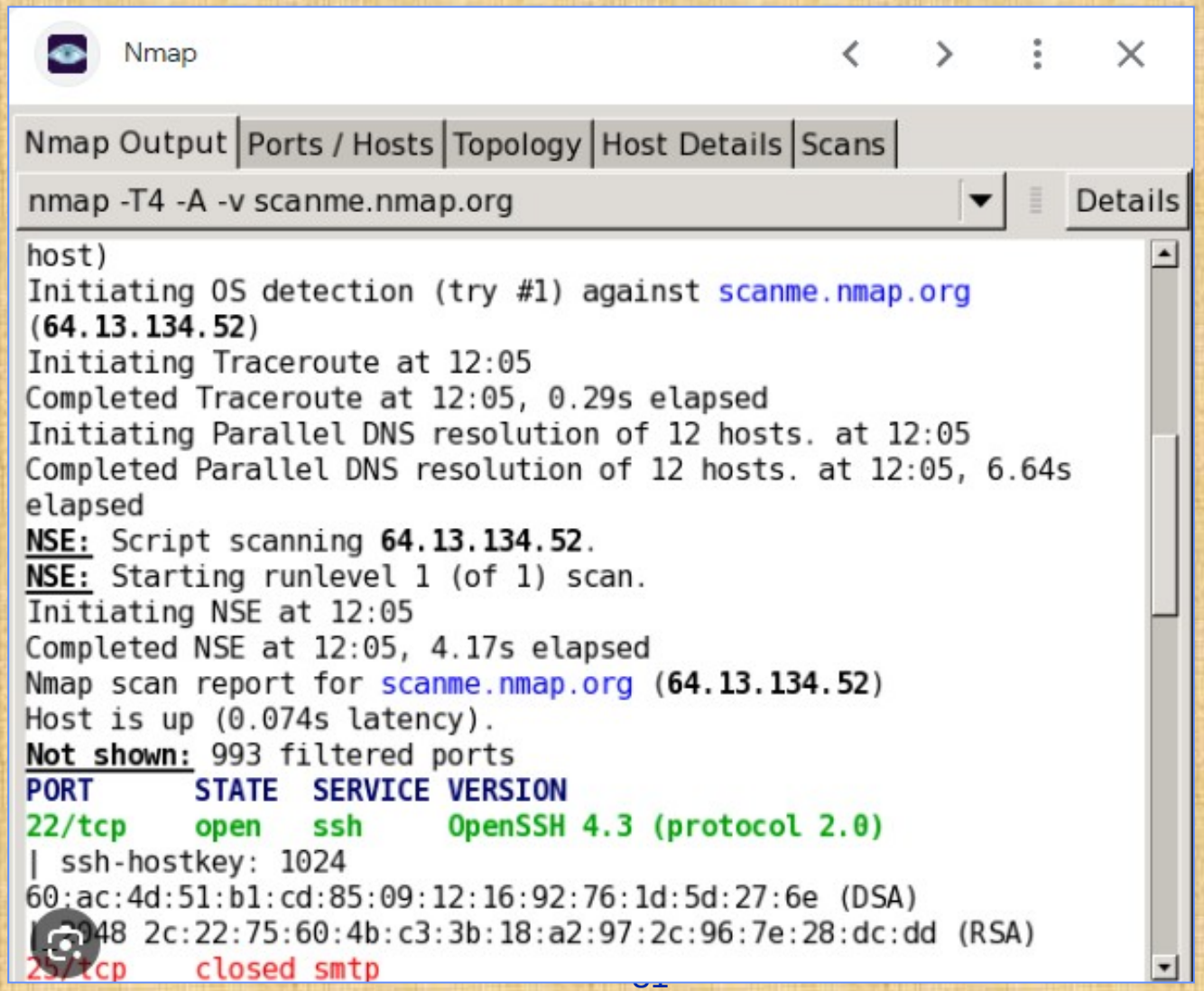
Starting Nmap 4.76 ( http://nmap.org ) at 2009-10-12 15:13 EDT
Interesting ports on 192.168.1.101:
Not shown: 995 closed ports
PORT     STATE SERVICE
22/tcp   open  ssh
5001/tcp open  commplex-link
8009/tcp open  ajp13
8180/tcp open  unknown
8888/tcp open  sun-answerbook
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.17 - 2.6.25
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.68 seconds
```

Open ports

OS version

NMap


Nmap
Nmap Output
Ports / Hosts
Topology
Host Details
Scans
nmap -T4 -A -v scanme.nmap.org
Details
host)
Initiating OS detection (try #1) against scanme.nmap.org (64.13.134.52)
Initiating Traceroute at 12:05
Completed Traceroute at 12:05, 0.29s elapsed
Initiating Parallel DNS resolution of 12 hosts. at 12:05
Completed Parallel DNS resolution of 12 hosts. at 12:05, 6.64s elapsed
NSE: Script scanning 64.13.134.52.
NSE: Starting runlevel 1 (of 1) scan.
Initiating NSE at 12:05
Completed NSE at 12:05, 4.17s elapsed
Nmap scan report for scanme.nmap.org (64.13.134.52)
Host is up (0.074s latency).
Not shown: 993 filtered ports
PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 4.3 (protocol 2.0)
| ssh-hostkey: 1024
60:ac:4d:51:b1:cd:85:09:12:16:92:76:1d:5d:27:6e (DSA)
2048 2c:22:75:60:4b:c3:3b:18:a2:97:2c:96:7e:28:dc:dd (RSA)
25/tcp closed smtp

Scanning and Exploiting

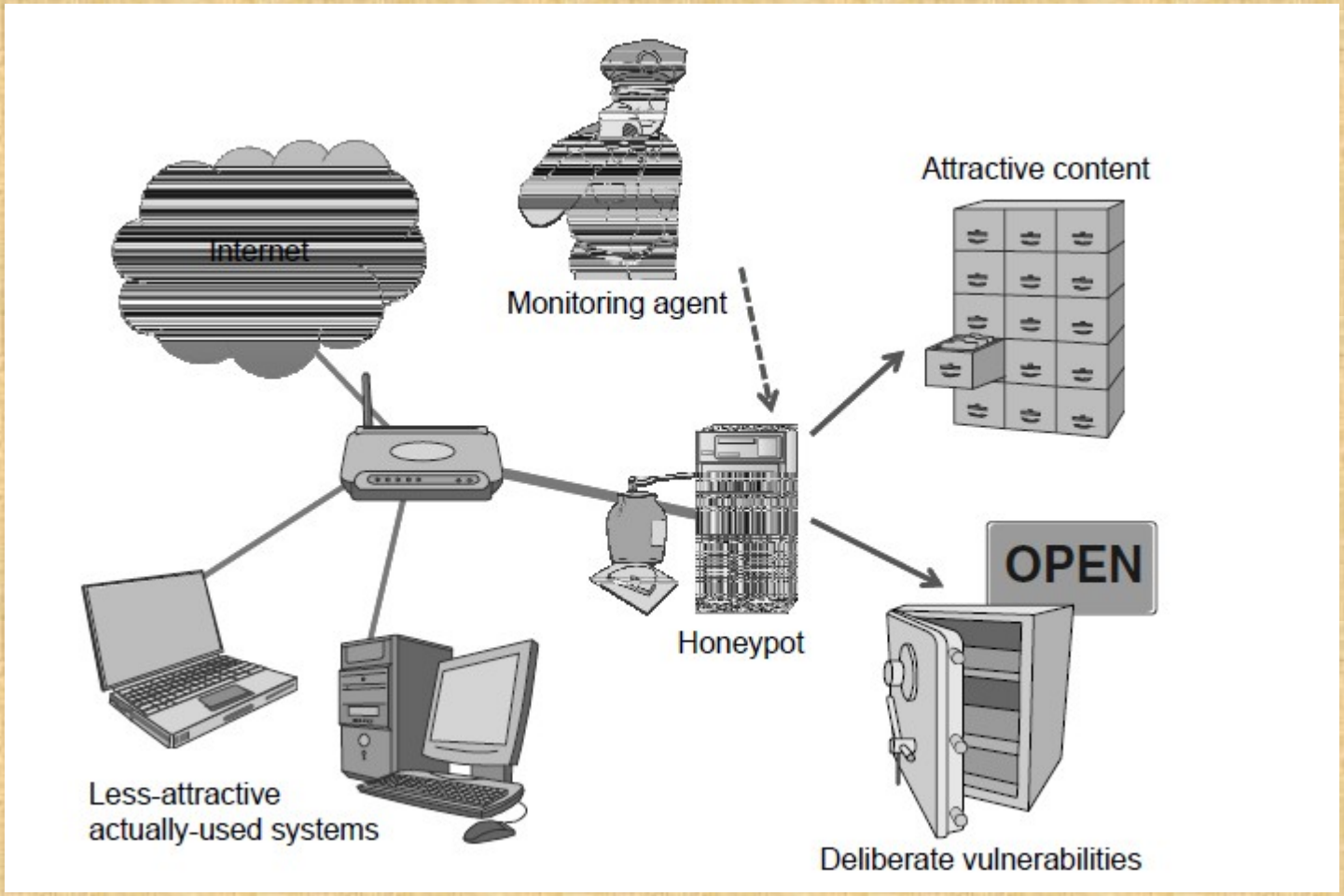
- Nmap is a network scanner utility used for port mapping, host discovery and vulnerability scanning.
- Most of its functions are based on using IP packet analysis to detect and identify remote hosts, operating systems and services.

- It can perform full scan: OS version

- Specific OS version can be checked in the CVE database to find out vulnerabilities

- Exploits can be used to get access to the system

Honetpots


Internet
Monitoring agent
Attractive content
Honeypot
OPEN
Less-attractive
actually-used systems
Deliberate vulnerabilities

Application of Honeypots

- **Intrusion detection:** Since attempts to connect to a honeypot would not come from legitimate users, any connections to a honeypot can be safely identified as intrusions
- **Evidence:** Appealing documents on a honeypot computer encourage an intruder to linger and leave evidence that can possibly lead to the identification of the intruder and/or his location
- **Diversion:** A honeypot also may appear to be more attractive to potential intruders than legitimate machines, distracting intruders from sensitive information and services.